

Open EDR – Tedarik Zinciri Zafiyet Raporu

Rapor Tarihi: 10 Temmuz 2026

Araştırmacı: Eneshan Erdoğan Karaca

GitHub: [Kisaca-Enes](#)

Durum: Full Disclosure

1. Özet

Open EDR (Xcitium / Comodo) projesi, bünyesinde barındırdığı **üçüncü parti kütüphaneleri 7–8 yıldır güncellememiştir**. Bu kütüphaneler, toplamda **12 adet doğrudan** ve **100'den fazla dolaylı CVE** içermektedir. Zafiyetler arasında **Uzaktan Kod Yürütme (RCE)**, **Veri Sızdırma**, **Hizmet Reddi (DoS)** ve **Güvenlik Bypass** bulunmaktadır.

Vendor'a (Xcitium/Comodo) **21 Haziran 2026** tarihinde bildirim yapılmış, **23 Haziran**'da "güncelleyeceğiz" yanıtı alınmış, ancak sonrasında gönderilen **4 ayı takip e-postası** cevapsız bırakılmıştır. Bu rapor, **sorumlu ifşa (responsible disclosure)** sürecinin tamamlanmasının ardından kamuoyunu bilgilendirmek amacıyla hazırlanmıştır.

2. Tedarik Zinciri Saldırısı (Supply Chain Attack)

Bir yazılımın doğrudan kendi kodundan ziyade, **kullandığı harici kütüphaneler** veya **bağımlılıklar** üzerinden gerçekleştirilen saldırı türüdür. Bir Python projesinde kullanılan bir kütüphanedeki zafiyet, o projeyi de doğrudan etkiler. Aynı mantıkla, Open EDR'nin kullandığı **cURL**, **OpenSSL**, **Boost**, **AWS SDK** gibi kütüphanelerdeki bilinen güvenlik açıkları, EDR'nin kendisini **savunmasız** hale getirmektedir.

Bu durum, **APT grupları** ve **siber saldırganlar** için doğrudan bir **sıfıncı gün (0-day)** vektörü oluşturmaktadır. Saldırganlar, doğrudan hedef sisteme sızmak yerine, hedefin kullandığı **güvenlik açığı bulunan bir bağımlılık** üzerinden sisteme erişim sağlayabilir. Bu yöntem, özellikle **güvenlik duvarları** ve **ağ izleme sistemleri** tarafından tespit edilmesi zor olan **sessiz** bir saldırı vektörüdür.

Örnek: Bir şirket, X firmasının yazılımını kullanıyor. X firmasının yazılımı, eski ve zafiyetli bir OpenSSL sürümü kullanıyor. Saldırgan, bu OpenSSL zafiyetini kullanarak X firmasının yazılımı üzerinden şirket ağına sızabiliyor. İşte bu bir **tedarik zinciri saldırısıdır**.

3. Etkilenen Bileşenler (Affected Components)

Aşağıdaki tabloda, Open EDR bünyesinde tespit edilen **12 doğrudan** güvenlik açığı ve ilişkili CVE'ler listelenmiştir. Her bir zafiyet **Vuln-001** ile **Vuln-012** arasında sınıflandırılmıştır.

ID	Kütüphane	Sürüm	İlgili CVE	Etki
Vuln-001	AWS SDK C++	1.7.63	CVE-2025-14760	Veri Bütünlüğü İhlali
Vuln-002	Boost	1.70.0	CVE-2023-52323	Heap Overflow – RCE
Vuln-003	cURL	7.63.0	CVE-2019-3822	Stack Overflow – RCE
Vuln-004	cURL	7.63.0	CVE-2018-16890	Bilgi Sızdırma
Vuln-005	cURL	7.63.0	CVE-2021-22890	MITM Saldırısı
Vuln-006	OpenSSL	1.1.1b	CVE-2026-41676	Buffer Overflow – RCE
Vuln-007	OpenSSL	1.1.1b	CVE-2019-1543	Nonce Tekrarı – Bilgi Sızıntısı

Vuln-008	OpenSSL	1.1.1b	CVE-2023-0215	Use-After-Free – RCE/DoS
Vuln-009	OpenSSL	1.1.1b	CVE-2023-0286	Type Confusion – Bilgi Sızıntısı
Vuln-010	OpenSSL	1.1.1b	CVE-2022-0778	Infinite Loop – DoS
Vuln-011	OpenSSL	1.1.1b	CVE-2023-0464	Kaynak Tüketimi – DoS
Vuln-012	OpenSSL	1.1.1b	CVE-2023-0465	Güvenlik Bypass

Toplamda 12 doğrudan CVE ve bu kütüphanelerin eski sürümlerinde bulunan **100+'dan fazla dolaylı CVE** bulunmaktadır. Özellikle **RCE (Uzaktan Kod Yürütme)** içeren zafiyetler, EDR'nin **SYSTEM** yetkisiyle çalışması nedeniyle **kritik** seviyededir.

4. Repository Referansları (Kanıtlar)

Aşağıdaki bağlantılar, tespit edilen zafiyetli kütüphane sürümlerinin **doğrudan kanıtlarıdır**. Her bir bağlantı, ilgili kütüphanenin Open EDR deposundaki **sürüm bilgisini** içeren dosyaya yönlendirir.

- **AWS SDK C++ (1.7.63):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/awssdkcpp/CHANGELOG.md>
- **Boost (1.70.0):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/boost/boost/version.hpp>
- **cURL (7.63.0):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/curl/RELEASE-NOTES>
- **OpenSSL (1.1.1b):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/openssl/openssl/README>

5. Vendor İletişim Süreci

Aşağıda, Xcitem (Comodo) ile yapılan yazışmaların **zaman çizelgesi** ve **içeriği** detaylandırılmıştır.

- **21 Haziran 2026** – İlk rapor, security@xcitem.com adresine gönderildi. Raporla, tespit edilen zafiyetli kütüphaneler ve olası etkileri açıklandı.
- **22 Haziran 2026** – Oleg Kalinin (Development Manager CCS) tarafından "Uzun zamandır güncellemedik, bir sonraki sürümde güncelleyeceğiz." şeklinde **tek bir cümlelik** bir yanıt alındı.
- **22 Haziran – 10 Temmuz 2026** – Güncelleme takvimi, CVE tahsisi ve ek teknik bilgi talebi içeren **4 ayrı takip e-postası** gönderildi.
- **10 Temmuz 2026 (bugün)** – Bu e-postaların **hiçbirine** herhangi bir yanıt alınamadı.

Dikkat: Comodo/Xcitem'un **resmî bir güvenlik politikası (security policy)** bulunmamaktadır. Ayrıca Open EDR deposunda projenin "ölü" (dead) veya "aktif" olduğuna dair herhangi bir ibare yer almamaktadır. Bu durum, kullanıcılar ve araştırmacılar için büyük bir belirsizlik ve risk oluşturmaktadır.

6. Comodo'nun Geçmişteki Benzer Tutumu

Comodo'nun güvenlik araştırmacılarına karşı **sorumsuz** tutumu daha önce de gündeme gelmiştir. Aşağıda iki önemli örnek verilmiştir:

- **2016 – Google Project Zero:** Google araştırmacıları, Comodo'da buldukları bir zafiyeti **12 gün** sonra kamuoyuna duyurmuştu. Comodo o dönemde "biz sorumlu ifşa kurallarına uyarız" diyerek tepki göstermiş, ancak **kendi politikalarının olmadığı** ortaya çıkmıştı.
- **2017 – Marcus Hutchins (MalwareTech):** Araştırmacı, Comodo'da bulunduğu bir zafiyeti (ComoDoS) defalarca bildirmesine rağmen **hiçbir yanıt alamamış** ve kamuoyuna duyurmak zorunda kalmıştı.

Bu örnekler, Comodo'nun güvenlik araştırmacılarına yönelik **sistematik bir duyarsızlık** sergilediğini göstermektedir. Mevcut durumda da

benzer bir tablo yaşanmaktadır.

7. Teknik Değerlendirme

Zafiyetlerin tespiti, **Ockham'ın usturası** (basit düşünme) prensibiyle, yalnızca **README**, **CHANGELOG** ve **version** dosyaları incelenerek yapılmıştır. Herhangi bir **fuzzing**, **debugger** veya **exploit geliştirme** çalışması yapılmamıştır.

Bu yaklaşım, tedarik zinciri zafiyetlerinin **ne kadar basit** bir şekilde tespit edilebileceğini göstermektedir. Saldırganlar da aynı yöntemleri kullanarak **kritik zafiyetleri** saniyeler içinde bulabilir.

Öneri: Yazılım geliştiricileri, **düzenli olarak** bağımlılıklarını gözden geçirmeli ve **güncel tutmalıdır**. Ayrıca, **güvenlik politikaları** oluşturarak araştırmacılara **net bir bildirim süreci** sunmalıdır.

8. Sonuç ve Öneriler

- Open EDR kullanıcıları:** Bu zafiyetlere karşı **önlem almalı**, güvenlik duvarı ve ağ izleme çözümleriyle riski azaltmalıdır.
- Xcitiu/Comodo:** Tüm üçüncü parti kütüphaneleri **ivedilikle güncellemeli** ve bir **güvenlik politikası** oluşturmalıdır.
- Proje durumu:** Open EDR ölü bir proje ise, bu durum **açıkça belirtilmeli** ve kullanıcılar uyarılmalıdır.
- Araştırmacılara saygı:** Güvenlik bildirimlerine **zamanında ve profesyonelce** yanıt verilmelidir.

Kritik Uyarı: Bu zafiyetler, bir EDR'nin **kendi güvenliğini** sorgulatmaktadır. Eğer bir EDR, kendi bünyesinde **7-8 yıllık** ve **100'den fazla CVE** içeren kütüphaneler barındırıyorsa, **koruduğu sistemleri** nasıl güvende tutabilir?

Not: Bu rapor, 30 günlük bekleme süresi ve 4 ayı takip e-postasına rağmen **vendor'dan anlamlı bir geri dönüş alınamaması** üzerine, **kamuoyunu bilgilendirme** amacıyla hazırlanmıştır. Amacımız, güvenlik farkındalığını artırmak ve açık kaynak projelerin daha güvenli hale gelmesine katkı sağlamaktır.

© 2026 BoxStrike Ekibinden. Eneshan Erdoğan Karaca – Bu belge özgürce paylaşılabilir ve referans gösterilebilir.